

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

Rate-Limit Behaviour Test Evidence - ffuf Run Part 2

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	Rate-limit behaviour continued
Result Type	ffuf testing evidence
Evidence Report File	11-no-rate-limiting-ffuf-running-p2-evidence-report.pdf
Testing Phase	Sustained Request Behaviour Review
Tool / Component	ffuf / Terminal
OWASP / Security Mapping	API4:2023 Unrestricted Resource Consumption
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

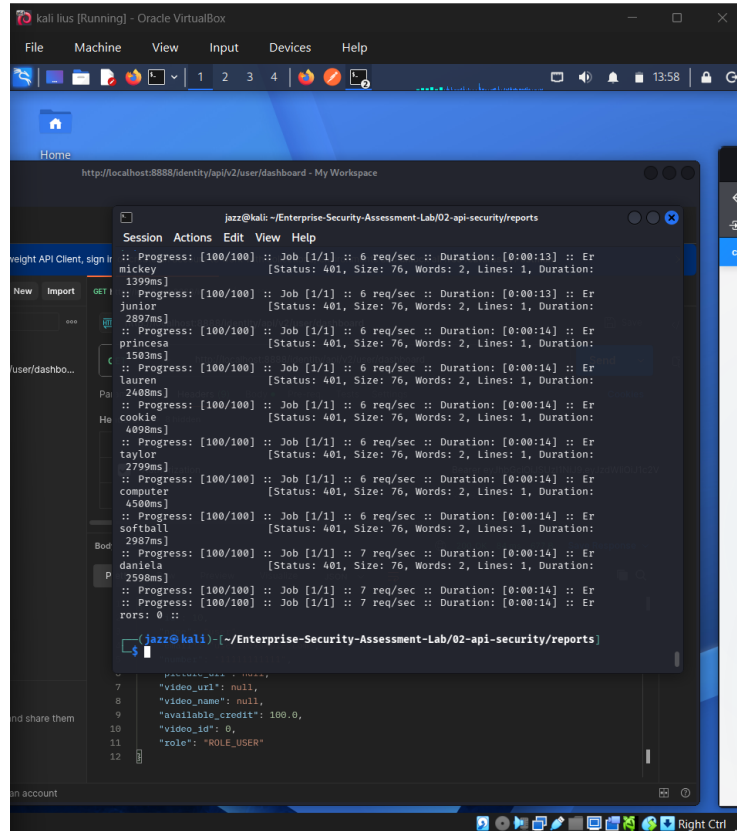


Figure 1 - Embedded screenshot evidence for: Rate-limit behaviour continued

What this evidence proves

The evidence shows continued ffuf output. This helps determine whether throttling appears only after a threshold or is absent in the tested path.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	Sustained Request Behaviour Review
Tool / Component	ffuf / Terminal
Assessment Objective	Continue the rate-limit test and review whether the API changes behaviour after repeated requests.
Result Type	ffuf testing evidence
OWASP / Security Mapping	API4:2023 Unrestricted Resource Consumption

Why this evidence matters

A single request does not prove rate-limit posture. A controlled sequence of repeated requests is needed to observe thresholds, response codes, and blocking behaviour.

Command / workflow used

```
Run low-to-moderate volume ffuf test
Monitor response codes
Check for 401/403/429/5xx patterns
Record whether throttling appears over time
```

Sanitized output style

```
Request volume: controlled lab test
Observed status codes: <REVIEWED>
Rate-limit signal: <429_OR_NONE>
Sensitive payload values: <REDACTED>
```

3. Professional Interpretation

This evidence row should be interpreted as: **ffuf testing evidence**.

Weak rate-limit behaviour can enable brute-force attempts, account enumeration, API scraping, or denial of service through high request volume.

Assessor notes

This evidence complements the first ffuf screenshot and provides continuity.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

Weak rate-limit behaviour can enable brute-force attempts, account enumeration, API scraping, or denial of service through high request volume.

Recommended remediation / hardening actions

- Enforce request quotas per IP, user, and endpoint.
- Use exponential backoff or cooldowns.
- Protect login and password reset endpoints first.
- Use monitoring alerts for burst activity.
- Apply API gateway throttling controls.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Endpoint payload.
- Emails/usernames.
- Tokens.
- Any generated wordlist values if private.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

`[Rate-limit behaviour continued](./reports/evidence/11-no-rate-limiting-ffuf-running-p2-evidence-report.pdf)`

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.